

Nimbus Cloud Technologies

Incident Response Policy

Purpose

This policy defines how the company detects, responds to, and recovers from security incidents affecting its systems, data, or customers.

Incident Classification

Incidents are classified as Low, Medium, High, or Critical based on the confidentiality, integrity, or availability impact. A Critical incident is one involving confirmed unauthorized access to customer data or a production outage affecting all customers.

Detection and Reporting

Employees who suspect a security incident, including a lost device, phishing email, or suspicious system behavior, must report it to security@nimbuscloud.example immediately. There is no penalty for reporting a good-faith suspicion that turns out to be a false alarm.

Response Team

A Critical or High severity incident is managed by the Incident Response Team, led by the on-call security engineer, with support from engineering, legal, and communications as needed.

Containment and Eradication

The response team's first priority is to contain the incident to prevent further impact, for example by revoking compromised credentials or isolating affected systems, before removing the root cause.

Customer and Regulator Notification

Customer and regulator notification for incidents involving personal data follows the timelines set out in the Data Privacy Policy. Legal counsel determines specific notification obligations for each incident.

Post-Incident Review

Every High or Critical incident is followed by a blameless post-incident review within 5 business days, documenting the root cause, impact, and follow-up actions to prevent recurrence.